Hito 3

Consentimiento, derechos, auditoría y respuesta a incidentes en NortiShop

Asignatura: Seguridad y Protección de Datos

Grupo: _____

Integrantes: Ariel Van Kilsdonk y Carlos Orellana

Caso: Plataforma de comercio electrónico NortiShop

Fecha: 29 de octubre de 2026

Índice

1 Introducción 2
2 Diseño del módulo de consentimiento 2
2.1 Finalidades y base de licitud 2
2.2 Modelo de datos, versiones y estados 3
2.3 Revocación y efectos en los procesos 3
2.4 Independencia entre finalidades 4
2.5 Flujo para menores de edad 4
2.6 Interfaz y evidencias del módulo 4
3 Ejercicio de derechos 5
3.1 Flujo de gestión de solicitudes 5
3.2 Verificación de identidad proporcional al riesgo 6
3.3 Acceso y portabilidad 6
3.4 Rectificación 7
3.5 Supresión 7
4 Diseño del registro de auditoría 8
4.1 Eventos y atributos 8
4.2 Información que no se registra 8
4.3 Protección, consulta y conservación 9
5 Plan de respuesta a incidentes 10
5.1 Preparación 10
5.2 Detección y análisis 10
5.3 Contención 11
5.4 Erradicación y recuperación 11
5.5 Notificación y comunicación 12
5.6 Lecciones aprendidas, escalamiento y cierre 13
6 Implementación e integración en el código 13
7 Evidencias de pruebas 14
8 Justificación técnica final 16
9 Referencias 16

La numeración de páginas comienza después de la portada.

1 Introducción

Este informe documenta el Hito 3 del caso NortiShop. A partir del inventario del Hito 1 y de la base rediseñada con RBAC del Hito 2, se diseñaron e implementaron cuatro mecanismos: la gestión del consentimiento por finalidad, el ejercicio de los derechos de acceso, portabilidad, rectificación y supresión, un registro de auditoría inmutable y un plan de respuesta a incidentes con procedimientos técnicos que lo soportan.

Todo está implementado en `Sistema_NortiShop` (Python, Flask y SQLite), integrado con los módulos del Hito 2 y cubierto por pruebas automatizadas. Lo que depende de infraestructura externa (correo transaccional, proveedor de mailing, pasarela de pago y KMS) se simuló con implementaciones de prueba que permiten verificar la lógica, y cada limitación se documenta.

Marco normativo. A la fecha de este informe (29 de octubre de 2026) rige la Ley 19.628. La Ley 21.719 la modifica desde el 1 de diciembre de 2026, apenas un mes después, por lo que el diseño apunta a cumplir el texto nuevo: consentimiento libre, específico, inequívoco e informado (art. 2 letra p y art. 12), derechos de acceso, rectificación, supresión y portabilidad (arts. 5, 6, 7 y 9), procedimiento ante el responsable (art. 11), deber de reportar vulneraciones (art. 14 sexies) y protección de niños, niñas y adolescentes (art. 16 quáter). Donde la ley actual difiere, se indica.

2 Diseño del módulo de consentimiento

2.1 Finalidades y base de licitud

El consentimiento no es la base de todo el tratamiento. Siguiendo el Hito 1, la compra, el despacho y la facturación se apoyan en la ejecución del contrato y en obligaciones legales, que la Ley 21.719 reconoce como fuentes de licitud distintas del consentimiento (art. 13). Por eso el módulo gestiona solo las finalidades opcionales, y ninguna compra queda condicionada a aceptarlas.

Finalidad (código)	Descripción	Base de licitud	Conservación
marketing_email	Ofertas y boletín por correo	Consentimiento específico y revocable	Mientras esté vigente; prueba de otorgamiento y revocación 3 años
personalizacion	Recomendaciones según el historial de compras	Consentimiento	Mientras esté vigente
analitica	Registro seudonimizado de navegación	Consentimiento	13 meses; luego solo agregados
guardar_medio_pago	Conservar el token de la pasarela	Consentimiento	Hasta revocación o 12 meses sin uso
Compra, pago y despacho	Ejecutar el pedido	Contrato (no se pide consentimiento)	Según el inventario del Hito 1
Facturación	Emitir y conservar la factura	Obligación legal	6 años propuestos (por validar)
Seguridad y auditoría	Prevenir fraude e investigar	Interés legítimo ponderado (desde 01-12-2026)	2 años

Tabla 1. Finalidades del tratamiento. Solo las cuatro primeras dependen del módulo de consentimiento.

2.2 Modelo de datos, versiones y estados

Tabla	Campos principales	Decisión de diseño
consent_purposes	code, name, description, retention	Catálogo cerrado: no se puede consentir una finalidad que no existe.
consent_texts	purpose_code, version, body, body_sha256, published_at, is_current	Cada texto informado se versiona y su hash prueba qué se mostró exactamente.
consent_events	subject_ref, purpose_code, text_version, action (otorgado | revocado), channel, occurred_at, prev_mac, mac	Historial solo de inserción: los triggers bloquean UPDATE y DELETE y cada evento se sella con HMAC encadenado.
consent_state (vista)	Último evento por titular y finalidad	El estado actual se deriva del historial, nunca se edita.
marketing_outbox	customer_ref, action (subscribe | suppress)	Propaga altas y bajas al proveedor de mailing sin enviarle la identidad.

Tabla 2. Modelo de datos del consentimiento.

Estados. Para cada finalidad el titular está en `no_otorgado` (estado inicial, sin casillas premarcadas), `otorgado` o `revocado`. Volver a otorgar crea un evento nuevo, de modo que el historial muestra cada cambio con su fecha y hora UTC, la versión del texto y el canal.

Versiones. Para otorgar, el cliente debe enviar la versión del texto que leyó. Si no coincide con la vigente, la operación se rechaza con el mensaje «La versión del texto informado no es la vigente; vuelva a leerlo». Así se garantiza un consentimiento informado sobre el texto actual. Cuando se publica una versión nueva, los consentimientos anteriores siguen registrados con su versión, y el equipo legal decide si la nueva exige renovarlos.

Trazabilidad sin datos innecesarios. El evento guarda un seudónimo (`subject_ref`) en lugar del correo, no guarda IP ni dispositivo y conserva solo lo que la pauta exige. Si el titular suprime su cuenta, se elimina el nexo del seudónimo pero la prueba de su revocación se conserva.

2.3 Revocación y efectos en los procesos

Finalidad revocada	Efecto inmediato en el sistema
marketing_email	Sale de la audiencia del endpoint de marketing y se encola `suppress` en `marketing_outbox` para el proveedor.
analitica	El endpoint de eventos deja de registrar y se eliminan los eventos seudonimizados existentes de esa persona.
guardar_medio_pago	Se eliminan los tokens guardados en `saved_payment_methods`.
personalizacion	Las recomendaciones pasan a ser genéricas; el historial deja de consultarse para ese fin.

Tabla 3. Efectos de la revocación (función apply_revocation en consent.py).

La revocación se registra como un evento nuevo con su fecha y hora. Revocar algo que no estaba otorgado responde 409 y no crea eventos falsos.

2.4 Independencia entre finalidades

El sistema no asume que una finalidad habilita otras porque no existe ninguna operación que reciba más de una finalidad: no hay «aceptar todo». La función `has_consent(cliente, finalidad)` consulta solo la fila de esa finalidad en `consent_state`, y cada proceso dependiente la llama con su propio código: analítica antes de registrar un evento, el checkout antes de guardar un token, el endpoint de recomendaciones y la audiencia de marketing. La prueba `test_each_purpose_is_independent` otorga solo marketing y verifica que las otras tres siguen en `no_otorgado`, que las recomendaciones son genéricas y que el medio de pago no se guarda.

2.5 Flujo para menores de edad

Por qué el flujo diferenciado no aplica. NortiShop vende tecnología a distancia con medios de pago bancarios, y sus productos y canales no están dirigidos a niños, niñas ni adolescentes. Comprar exige celebrar un contrato y pagar con un medio propio, por lo que la tienda se reserva para mayores de 18 años y el Hito 1 ya establecía que no debía recolectar datos de menores por defecto. Diseñar un flujo de consentimiento parental implicaría recolectar datos de menores y de sus representantes que la finalidad del sistema no necesita.

Cómo se asegura. El registro exige la declaración `declaro_mayor_de_edad = true` y no pide la fecha de nacimiento (minimización). Si alguien descubre que la cuenta pertenece a un menor (por un reclamo de su representante, soporte o una revisión interna), el DPO usa `POST /api/dpo/clientes/<id>/reporte-menor`, que deshabilita la cuenta, revoca sus sesiones, anula y reembolsa los pedidos en curso y suprime los datos con el procedimiento de supresión. Como un menor de 14 años no puede consentir por sí mismo sin su representante (art. 16 quáter), esos datos no tienen base válida y la supresión procede (art. 7). Si en el futuro NortiShop quisiera admitir adolescentes, debería implementar verificación de edad y la intervención del representante legal según ese artículo.

2.6 Interfaz y evidencias del módulo

El centro de privacidad (`/privacidad`) muestra cada finalidad con su texto, versión, plazo de conservación y estado, un botón independiente para autorizar o revocar, el historial completo y las solicitudes de derechos.

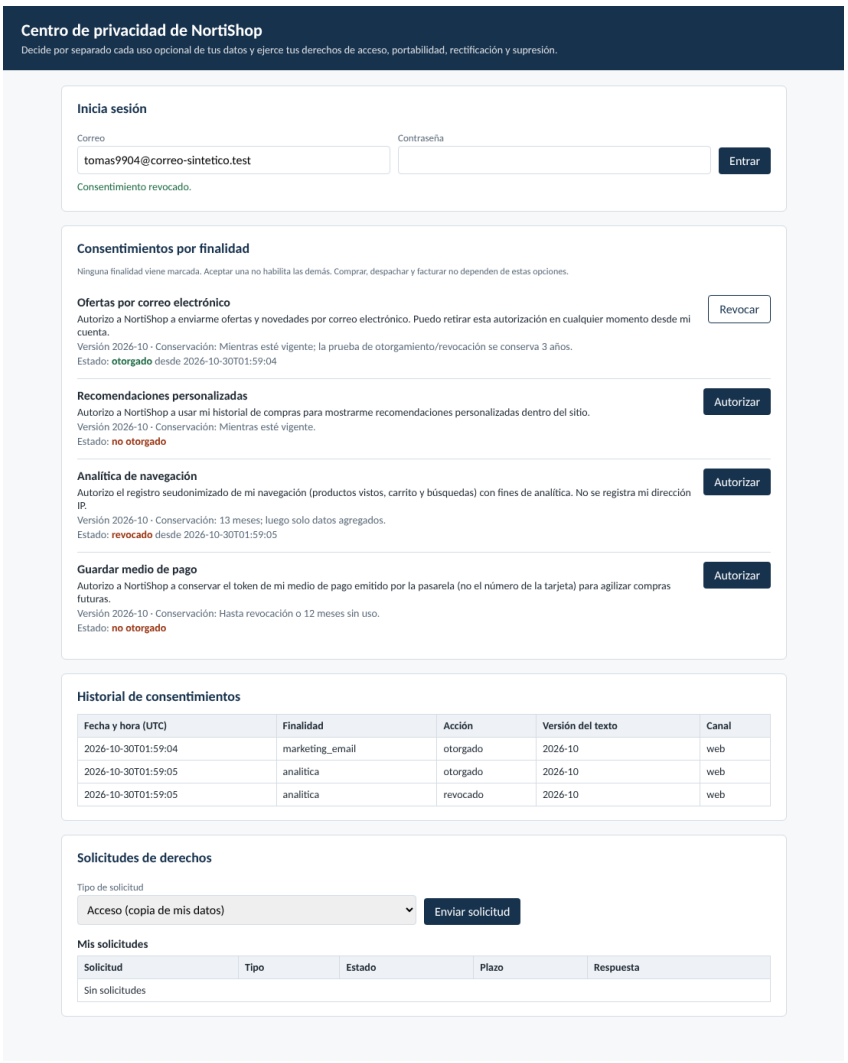


Figura 1. Centro de privacidad: marketing otorgado, analítica otorgada y luego revocada; las demás finalidades siguen sin otorgar. Datos sintéticos.

El historial que devolvió el sistema en la ejecución de evidencia, tal como queda en la base:

Id	Seudónimo del titular	Finalidad	Versión	Acción	Fecha y hora UTC	Sello HMAC
1	ps_f50c1bcd02077dcdb235	analitica	2026-10	otorgado	2026-10-30T01:58:59	c1e8eb1b5cb2fb1a…
2	ps_f50c1bcd02077dcdb235	marketing_email	2026-10	otorgado	2026-10-30T01:58:59	fd322ba24c2c7f41…
3	ps_f50c1bcd02077dcdb235	analitica	2026-10	revocado	2026-10-30T01:58:59	6afaa5cf7d46f254…

Tabla 4. Eventos de consentimiento. Verificación de la cadena HMAC: válida.

3 Ejercicio de derechos

3.1 Flujo de gestión de solicitudes

Todas las solicitudes siguen el mismo flujo, con cada transición registrada en `rights_request_events` y en la auditoría:

Estado	Qué ocurre	Responsable
recibida	El titular autenticado crea la solicitud. Se validan el tipo y, en rectificación, los datos propuestos. Se fija el plazo de 30 días corridos.	Titular / sistema

Estado	Qué ocurre	Responsable
verificacion	Se exige la verificación de identidad según el riesgo (3.2).	Titular
evaluacion	Se revisan las reglas de negocio y las excepciones legales (pedidos en curso, obligación tributaria, exportaciones congeladas por un incidente).	Sistema; DPO en casos manuales
ejecutada o rechazada	Se ejecuta, o se rechaza con una respuesta fundamentada que indica el derecho a reclamar ante la Agencia dentro de 30 días hábiles.	Sistema / DPO
cerrada	Se cierra y se borran los valores temporales (por ejemplo, el teléfono propuesto). El acceso se cierra al vencer la ventana de descarga de 24 horas.	Sistema

Tabla 5. Estados de una solicitud.

Plazos. Según el art. 11 de la Ley 19.628 modificada, el responsable debe pronunciarse dentro de 30 días corridos desde el ingreso, prorrogables una sola vez hasta por 30 días. `due_at` se calcula al recibir la solicitud; el DPO puede prorrogarla una vez con un motivo (`/api/dpo/solicitudes/<id>/prorroga`) y un segundo intento responde 409. El panel del DPO marca las solicitudes vencidas y no expone datos personales. Hasta el 30 de noviembre de 2026 rige el procedimiento de la ley actual, más breve; el sistema responde las solicitudes automáticas de inmediato, así que cumple ambos marcos.

3.2 Verificación de identidad proporcional al riesgo

Solicitud	Riesgo	Verificación exigida
Rectificación de nombre, teléfono o dirección	Medio: modifica datos propios	Sesión activa + reingreso de la contraseña
Rectificación de correo	Alto: cambia el canal de recuperación de la cuenta	Sesión + contraseña + código enviado al correo registrado
Acceso o portabilidad	Alto: entrega todos los datos	Sesión + contraseña + código de un solo uso
Supresión	Alto e irreversible	Sesión + contraseña + código de un solo uso

Tabla 6. Verificación proporcional. El código tiene 6 dígitos, dura 10 minutos, admite 5 intentos y se guarda solo como hash.

La verificación no pide datos adicionales (ni copia de cédula ni fotografía), porque el titular ya está identificado por su cuenta y su correo, y pedir más contradiría la minimización. Si alguien intenta verificar o descargar la solicitud de otra persona, recibe 404, la misma respuesta que para una solicitud inexistente, para no revelar que existe. El personal no puede usar estos endpoints porque requieren el permiso `derechos:solicitar_propio`.

3.3 Acceso y portabilidad

Una vez ejecutada la solicitud, el titular descarga durante 24 horas un archivo JSON UTF-8 estructurado, con formato declarado (`NortiShop-portabilidad/1.0`) y legible por máquinas. Contiene titular, direcciones, pedidos con ítems y pago enmascarado, NortiPuntos, reseñas, estado e historial de consentimientos y medios de pago guardados (marca y últimos 4 dígitos).

Exclusiones explícitas: hash de contraseña, tokens de sesión y de pago, códigos de autorización, alertas y registros de seguridad, notas internas y datos de otros clientes. La prueba de acceso verifica que la exportación no contiene el correo ni el nombre de otro cliente, el token de la pasarela, el código de autorización ni ningún hash. Cada descarga genera el evento `datos.exportacion`, y más de 3 descargas en

24 horas disparan una alerta de exportación anómala. Si hay un incidente con exportaciones congeladas, la solicitud queda en evaluación dentro del plazo legal.

3.4 Rectificación

- **Validación:** los datos propuestos pasan por las mismas reglas del sistema (teléfono móvil chileno, correo, región del catálogo, largo de los textos), y cualquier campo fuera de la lista blanca se rechaza. En la evidencia, un teléfono «12» se rechazó con «largo permitido 8-20».
- **Trazabilidad:** la auditoría registra qué campos cambiaron, no los valores. El valor propuesto se guarda cifrado mientras la solicitud está abierta y se borra al cerrarla.
- **Propagación:** al corregir una dirección se actualizan los pedidos aún no despachados, y al corregir el teléfono, también los que están en tránsito, para que logística vea el dato correcto. Las facturas ya emitidas no se modifican porque son documentos tributarios. Un correo nuevo se rechaza si ya pertenece a otra cuenta.

Resultado en la evidencia: «Datos corregidos: telefono. Pedidos en curso actualizados: 1. Las facturas ya emitidas no se modifican (documento tributario).».

3.5 Supresión

Situación	Tratamiento	Fundamento
Pedidos en curso	Se rechaza con fundamento; puede pedirse de nuevo tras la entrega o anulación	Ejecución del contrato (art. 7)
Cuenta, correo, teléfono, contraseña y sesiones	Se eliminan o anulan; el índice del correo se reemplaza	Finalidad cumplida o consentimiento revocado
Direcciones, tokens guardados, NortiPuntos, eventos de analítica	Se eliminan	Sin obligación de conservar
Reseñas y tickets	La reseña se desvincula (alias «Cliente») y el mensaje del ticket se borra	La opinión publicada pierde el nexo con la persona
Pedidos entregados y facturas	Se borran destinatario, teléfono y calle; se conservan monto, ítems, comuna/región y fecha, y el perfil de factura queda bloqueado hasta `retention_until`	Obligación legal tributaria (art. 7)
Consentimientos	Se registra la revocación de los vigentes y se desvincula el id interno; queda la prueba seudonimizada	Defensa ante reclamos (art. 7)
Seudónimos	Se borran sus filas en `pseudonym_vault`: lo seudonimizado restante pasa a ser anónimo	Anonimización
Marketing	Baja al proveedor y registro del índice ciego del correo en `suppression_list`	Evita volver a contactarlo sin guardar el correo
Respaldos	Se registra una lápida (`erasure_tombstones`); al restaurar un respaldo, `reapply-erasures` vuelve a suprimir	La supresión persiste aunque se restaure
Auditoría	Se conserva sin datos personales (solo identificadores opacos) hasta su plazo de 2 años	Seguridad y defensa de derechos

Tabla 7. Condiciones y alcance de la supresión (función erase_customer).

La información suprimida deja de usarse: la prueba de supresión verifica que el titular ya no puede iniciar sesión, no aparece en la audiencia de marketing ni en la vista de soporte, y que la cadena de consentimientos sigue verificando. Las supresiones se ejecutan en una sola transacción, así que no quedan supresiones a medias.

4 Diseño del registro de auditoría

4.1 Eventos y atributos

Las acciones auditadas forman un catálogo cerrado (`AUDITED_ACTIONS`): registrar una acción no catalogada lanza un error, lo que evita eventos ambiguos.

Categoría	Eventos
Autenticación	auth.registro, auth.login (ok o denegado), auth.logout, auth.bloqueo
Datos personales	datos.lectura_sensible (logística), datos.lectura_enmascarada (soporte), datos.modificacion, datos.exportacion, datos.supresion
Consentimiento	consentimiento.otorgado, consentimiento.revocado, consentimiento.consulta (DPO)
Derechos	derechos.solicitud, verificacion, evaluacion, ejecucion, rechazo, prorroga, cierre
Administración	admin.cambio_rol, admin.estado_pedido, seudonimo.reversion, menores.reporte, sistema.rotacion_llaves
Seguridad	acceso.denegado (aplicación o base de datos), seguridad.alerta, incidente.apertura, evidencia, contencion, recuperacion, cierre, error.interno
Auditoría	auditoria.consulta, auditoria.verificacion, auditoria.purga (consultar el registro también queda registrado)

Tabla 8. Eventos auditados.

Atributo	Contenido
event_id	UUID único del evento
occurred_at	Fecha y hora UTC
actor_type, actor_ref, actor_role	Tipo (cliente, personal, anónimo o sistema), public_id opaco y rol
action	Operación del catálogo
resource_type, resource_ref	Recurso afectado por identificador interno (pedido, solicitud, endpoint)
result	ok, denegado, rechazado o error
request_id	Correlación con el log técnico y con la respuesta enviada al usuario
ip_prefix	Red /24 (IPv4) o /48 (IPv6), no la IP completa
details	JSON saneado con contexto mínimo (por ejemplo, nombres de campos modificados)
prev_hash, hash	HMAC encadenado que hace evidente cualquier manipulación

Tabla 9. Atributos de cada registro.

4.2 Información que no se registra

Nunca se registran contraseñas, tokens de sesión o de pago, códigos de verificación, llaves criptográficas, números de tarjeta, el contenido de datos personales (nombre, correo, teléfono, dirección, RUT) ni los valores antes y después de una rectificación. Esto se aplica en código, no por convención: `sanitize()`

reemplaza por «[omitido]» cualquier clave cuyo nombre contenga password, token, code, codigo, key, cvv o tarjeta, y enmascara en los textos todo lo que tenga forma de correo, RUT, teléfono o número de tarjeta. La prueba `test_events_have_required_attributes_and_no_personal_data` revisa que el registro completo no contenga ninguno de esos valores.

4.3 Protección, consulta y conservación

- **Modificación:** triggers `audit_no_update` y `audit_no_early_delete` que actúan incluso sobre la conexión de sistema, más la cadena HMAC con una llave que no está en la base. Si alguien con acceso al archivo elimina los triggers y altera un evento, la verificación falla y se abre automáticamente un incidente crítico.
- **Acceso no autorizado:** solo leen el auditor, el DPO y el oficial de seguridad, en las dos capas (permiso `auditoria:leer` y política de base de datos). Ningún rol tiene permiso de escritura sobre `audit_log`: inserta solo el servicio interno.
- **Eliminación indebida:** el trigger impide borrar registros con menos de 2 años. La purga de retención (`cli.py purge-audit`) borra solo los vencidos y deja un ancla (`audit_anchor`) con el último hash, para que la cadena siga verificando.
- **Conservación:** 2 años. Ese plazo cubre la detección tardía de incidentes y el periodo de reclamos, y luego se eliminan. Las copias que se preservan como evidencia de un incidente siguen el plazo del caso y se guardan con su SHA-256.

Equilibrio. Los identificadores opacos, el `request_id` y el prefijo de red bastan para reconstruir quién hizo qué, cuándo, sobre qué recurso y con qué resultado, y para cruzar el registro con los logs técnicos. Copiar datos personales no aportaría a la investigación y convertiría la auditoría en otra base que proteger. Si una investigación necesita identificar a un titular, el DPO resuelve el `public_id` con un motivo auditado.

Ejemplos reales generados durante la ejecución de evidencia (hashes truncados):


```
{ "event_id": "f8ebef9a-377a-4578-b9bb-e52d26bb9e52", "occurred_at": "2026-10-30T01:59:02",
"actor_type": "s
taff", "actor_ref": "aa22bd77-d8aa-4219-8adb-0fca86fa0a36", "actor_role": "marketing",
"action": "acceso.den
egado", "resource_type": "endpoint", "resource_ref": "/api/auditoria", "result":
"denegado", "request_id": "
bd075218292d4687", "ip_prefix": "127.0.0.0/24", "details": { "metodo": "GET", "motivo":
"rol_sin_permiso", "
permiso": "auditoria:leer" }, "prev_hash": "c675b222a61e6dc0…", "hash": "11a4f0ba468dd84f…"
}

{ "event_id": "9d38fe7c-27c8-4b17-b6a3-a286ab36d857", "occurred_at": "2026-10-30T01:59:02",
"actor_type": "s
taff", "actor_ref": "1f371c46-48c1-4135-b2af-00dda69596bf", "actor_role":
"oficial_seguridad", "action": "in
cidente.contencion", "resource_type": "incidente", "resource_ref": "INC-33D24654",
"result": "ok", "request_
id": "a034629919a34729", "ip_prefix": "127.0.0.0/24", "details": { "accion":
"congelar_exportaciones", "obje
tivo": null }, "prev_hash": "fda57a4096fc3fe0…", "hash": "f8343657f9c6c873…" }
```

Verificación de la cadena: 173 registros válidos. En una copia manipulada (trigger eliminado y un «denegado» cambiado por «ok»), la verificación falló en el registro 27.

5 Plan de respuesta a incidentes

El plan se adapta a los riesgos que identificaron los hitos anteriores: filtración de identidades, direcciones e historial; manipulación de pagos, NortiPuntos o consentimientos; abuso de credenciales del personal; e indisponibilidad del checkout o de los canales para ejercer derechos.

5.1 Preparación

Rol	Responsabilidades en un incidente
Oficial de seguridad (coordinador)	Recibe reportes, clasifica, declara incidentes, coordina las fases, ejecuta contención y recuperación en el sistema y decide el cierre.
DPO	Evalúa el impacto sobre los datos personales y el riesgo para los titulares, decide junto a gerencia si se notifica y redacta la comunicación a la Agencia y a los titulares.
Líder de desarrollo	Analiza la causa en el código, desarrolla y prueba la corrección y rota llaves si corresponde.
Administrador de sistemas	Aísla componentes, gestiona respaldos, restaura y aplica `reapply-erasures`, y revisa la configuración.
Gerencia y comunicaciones (con asesoría legal)	Autoriza las comunicaciones externas y la relación con la pasarela de pago, proveedores y prensa.

Tabla 10. Responsables. La asignación de personas se registra en la ficha de contactos del equipo, fuera del repositorio.

- **Canales de reporte:** seguridad@nortishop.cl, con guardia de lunes a domingo; el formulario interno de incidentes; las alertas automáticas del detector (`security_alerts`); y el aviso de clientes por el canal de soporte, que se deriva al oficial de seguridad en menos de 1 hora.
- **Recursos técnicos:** endpoints de contención y recuperación (`/api/seguridad/incidentes/...`), verificación de auditoría (`/api/auditoria/verificar`), CLI para rotar llaves, purgar y reaplicar supresiones, respaldos cifrados diarios con retención de 35 días y plantillas de notificación (5.5).
- **Procedimientos previos:** inventario de datos (Hito 1), matriz RBAC (Hito 2), un simulacro semestral y la revisión trimestral de cuentas del personal.

5.2 Detección y análisis

Regla automática	Criterio	Nivel inicial
fuerza_bruta_login	5 o más intentos fallidos sobre una cuenta en 10 minutos (además, la cuenta se bloquea 15 minutos)	Sospechoso
accesos_denegados_reiterados	5 o más respuestas 401/403, o rechazos del authorizer, de un mismo actor en 10 minutos	Sospechoso
exportacion_anomala	3 o más exportaciones de datos de un titular en 24 horas	Sospechoso
lectura_masiva_clientes	50 o más consultas de listados de clientes de un mismo funcionario en 10 minutos	Sospechoso
integridad_auditoria	La verificación de la cadena de auditoría falla	Incidente crítico (automático)
Reporte manual	Credenciales expuestas, modificaciones no autorizadas o reclamos de titulares	Lo evalúa el oficial

Tabla 11. Criterios de detección (nortishop/security.py).

Alerta, evento sospechoso e incidente. Una **alerta** es una señal aislada que se registra y se revisa en lote (por ejemplo, un acceso denegado). Un **evento sospechoso** ocurre cuando una regla supera su umbral; el oficial debe analizarlo en menos de 4 horas y puede descartarlo o escalarlo. Un **incidente confirmado** existe cuando hay evidencia de que se comprometió la confidencialidad, integridad o disponibilidad de datos personales, o cuando falla la integridad de la auditoría; abre un caso en `incidents` y habilita la contención.

Severidad	Criterio de alcance e impacto	Escalamiento
Baja	Sin acceso a datos personales; un usuario afectado	Oficial de seguridad
Media	Intento contra una cuenta o acceso indebido a datos enmascarados	Oficial + DPO dentro de 24 h
Alta	Acceso a datos personales completos de varios titulares o exportación anómala	Comité completo dentro de 4 h
Crítica	Filtración masiva, datos de pago, manipulación de la auditoría o caída del checkout por más de 1 h	Comité completo de inmediato y gerencia

Tabla 12. Severidad y escalamiento. Para evaluar el alcance se consultan la auditoría (actor, recursos, período), los registros afectados y las categorías del inventario del Hito 1.

5.3 Contención

Acción	Endpoint o procedimiento	Cuándo
Revocar sesiones	contencion: revocar_sesiones (cliente o personal)	Credencial comprometida o fuerza bruta exitosa
Deshabilitar cuenta	contencion: deshabilitar_cuenta	Cuenta del personal comprometida o abuso interno
Restringir permisos	Cambio de rol, que revoca sesiones; roles protegidos solo con doble aprobación	Privilegios excesivos detectados
Congelar exportaciones	contencion: congelar_exportaciones (responde 423)	Exportación anómala o sospecha de exfiltración
Aislar escrituras	contencion: modo_solo_lectura (responde 503 en escrituras, salvo seguridad)	Manipulación de datos en curso
Aislar componentes	Retirar del balanceador y bloquear la red del componente afectado	Compromiso del servidor

Tabla 13. Acciones de contención.

Preservación de evidencia. Antes de la primera acción de contención, el sistema guarda automáticamente una copia JSON de la auditoría, las alertas y el conteo de sesiones activas, y registra su SHA-256 en `incident_actions`. Las acciones revocan o bloquean, nunca borran: no se eliminan sesiones, cuentas ni registros. Los servidores comprometidos se aíslan sin apagarse hasta capturar memoria y discos, y toda acción manual queda en la ficha del incidente.

5.4 Erradicación y recuperación

- **Eliminar la causa:** corregir la vulnerabilidad (parche con prueba de regresión), forzar el cambio de contraseña de las cuentas afectadas, retirar credenciales expuestas y, si una llave pudo quedar

expuesta, rotarla: agregar la versión nueva a `NORTISHOP_DATA_KEYS`, ejecutar `rotate-keys` (que recifra toda la base) y retirar la llave anterior.

- **Restaurar con datos íntegros:** si se restaura un respaldo, ejecutar `reapply-erasures` para que no reaparezcan titulares suprimidos.
- **Comprobaciones antes de reabrir:** el endpoint de recuperación se niega a restablecer si la auditoría no verifica; además se exige la suite de pruebas en verde, que la causa esté documentada como erradicada (campo obligatorio), revisar cuentas y roles, y monitoreo reforzado durante 72 horas.

5.5 Notificación y comunicación

Criterio normativo. Desde el 1 de diciembre de 2026, el art. 14 sexies de la Ley 19.628 modificada obliga a reportar a la Agencia de Protección de Datos Personales las vulneraciones que causen destrucción, filtración, pérdida o alteración de datos, o comunicación o acceso no autorizados, cuando exista un **riesgo razonable** para los derechos de los titulares. También obliga a comunicarlo a los titulares cuando afecte **datos sensibles, datos de menores de 14 años o datos de obligaciones económicas, financieras, bancarias o comerciales**. En NortiShop, este último criterio cubre los pagos y el historial de compras. La función `notification_assessment` implementa esa regla y el endpoint `evaluacion-notificacion` deja la decisión registrada en el incidente.

Plazos. La ley no fija horas: exige reportar «por los medios más expeditos posibles y sin dilaciones indebidas». El plan fija metas internas para cumplirla: evaluación preliminar en 24 horas desde la confirmación, reporte a la Agencia dentro de 72 horas y comunicación a los titulares sin demora una vez contenido el incidente. Hasta el 30 de noviembre de 2026, la Ley 19.628 vigente no impone un deber general de notificar, pero se aplicará el mismo procedimiento como buena práctica y por el deber de cuidado (art. 11). Además, el contrato con la pasarela exige avisarle cualquier compromiso de datos de pago. Si la ANCI calificara a NortiShop como servicio esencial u operador de importancia vital, se agregarían los reportes al CSIRT Nacional de la Ley 21.663: alerta temprana en 3 horas, segundo reporte en 72 horas (24 si afecta un servicio esencial) e informe final en 15 días. No se asume un plazo universal para todos los incidentes.

Quién decide. El DPO evalúa el riesgo y redacta, y la gerencia con asesoría legal autoriza. El oficial de seguridad aporta los hechos técnicos. Cada comunicación queda registrada, como exige el mismo artículo.

Contenido de la comunicación:

1. Descripción clara del incidente en lenguaje sencillo.
2. Fecha de detección y, si se conoce, período en que ocurrió.
3. Tipos de datos personales potencialmente afectados (según el inventario del Hito 1).
4. Posibles consecuencias o riesgos para los titulares (phishing, fraude, suplantación).
5. Medidas de contención y mitigación adoptadas.
6. Recomendaciones para reducir los riesgos (cambiar contraseña, desconfiar de correos que pidan datos, revisar el estado de cuenta de la tarjeta).
7. Canal de contacto para consultas y seguimiento: privacidad@nortishop.cl y el centro de privacidad.

La comunicación se envía a cada titular afectado. Si eso no es posible, se publica en un medio de comunicación masivo de alcance nacional, como establece el art. 14 sexies.

5.6 Lecciones aprendidas, escalamiento y cierre

Lecciones aprendidas. Dentro de los 10 días siguientes a la recuperación, el comité documenta las causas raíz, las medidas correctivas y preventivas y las mejoras a los controles, procedimientos y reglas de detección. El cierre en el sistema exige registrar esos tres campos.

Criterios de escalamiento. Se sube un nivel de severidad si aumenta el número de titulares afectados, si se confirma acceso a datos completos o de pago, si la contención no surte efecto en 4 horas o si se afecta la auditoría.

Condiciones de cierre (verificadas por el endpoint de cierre): no queda ninguna medida de contención activa (modo solo lectura ni exportaciones congeladas), existe una evaluación de notificación registrada, la auditoría verifica y las lecciones aprendidas están documentadas.

Ciclo ejecutado en la evidencia (incidente INC-33D24654):

Acción registrada	Resultado	SHA-256 de evidencia
preservar_evidencia	ok	ce8c62f6f62e4497d8e0…
revocar_sesiones	1 sesiones revocadas	–
congelar_exportaciones	exportaciones congeladas	–
erradicacion	Bloqueo de cuenta y cambio de contraseña forzado	–
descongelar_exportaciones	exportaciones restablecidas	–
evaluacion_notificacion	{"reportar_agencia": false, "comunicar_titulares": false, "plazo": "no aplica; se document	–
lecciones_aprendidas	{"causas": "Contraseña del titular reutilizada en un sitio filtrado", "medidas_correctivas	–

Tabla 14. Acciones del incidente de prueba (fuerza bruta contra una cuenta), desde la preservación de evidencia hasta las lecciones aprendidas.

6 Implementación e integración en el código

Requisito	Implementación	Decisión y justificación
Consentimiento por finalidad con fecha, versión y estado	consent.py; tablas consent_*	Historial solo de inserción en lugar de una columna de estado: conserva cada cambio y su prueba sin poder reescribirse.
Revocación y su procesamiento	ConsentService.revoke, apply_revocation, marketing_outbox	Una outbox desacopla al proveedor externo: la baja queda registrada aunque el proveedor no esté disponible.
Verificación de identidad y autorización	rights.py: verify, _get_owned; permiso derechos:solicitar_propio	El código se guarda como hash; los intentos están limitados; responder 404 a terceros evita enumerar solicitudes.
Consultar, exportar, rectificar y suprimir	build_export, _rectify, erase_customer	Reglas de negocio explícitas (pedidos activos, facturas, ventana de 24 horas) y una sola transacción para la supresión.

Requisito	Implementación	Decisión y justificación
Auditoría automática y protegida	audit.py; audit_current() en cada endpoint	HMAC encadenado + triggers + escritura exclusiva del servicio; catálogo cerrado de acciones.
Detección y alertas	security.Detector.evaluate	Umbrales sobre la propia auditoría, sin infraestructura adicional y con deduplicación por ventana.
Contención y recuperación	Endpoints /api/seguridad/…; maintenance.py; cli.py	Banderas de sistema (solo lectura, exportaciones) que se revisan en cada solicitud; la recuperación exige que la auditoría verifique.

Tabla 15. Requisitos de implementación y decisiones.

Integración y controles que no se pueden eludir. Los módulos del Hito 3 usan los del Hito 2: el mismo `require` y el mismo authorizer por rol, el cifrado por campo de `crypto.py` en las exportaciones y rectificaciones, y los seudónimos de `privacy.py` en los consentimientos. Las pruebas demuestran que una solicitud directa al servidor no evade los controles: un token inventado o revocado recibe 401, un rol sin permiso 403, una solicitud ajena 404, y una consulta SQL directa desde la conexión de un rol a una tabla no autorizada la rechaza el motor. Además, las tablas de consentimiento y auditoría resisten un UPDATE o DELETE incluso desde la conexión de sistema, y si alguien elimina los triggers con acceso al archivo, la verificación HMAC detecta el cambio.

7 Evidencias de pruebas

La suite completa ejecuta 47 pruebas, todas aprobadas (`evidencias/resultado_pruebas.txt`). Las 29 del Hito 3 son:

Grupo	Pruebas (resultado OK)
Consentimiento (8)	nada otorgado por defecto; finalidades independientes; versión desactualizada rechazada; registro con fecha, finalidad, versión, estado y seudónimo; revocación registrada y propagada (audiencia, outbox, analítica); revocar «guardar medio de pago» borra el token; historial inmutable y manipulación detectada; el personal no gestiona consentimientos ajenos
Derechos (7)	flujo de portabilidad con contraseña y código, sin datos ajenos ni internos; otro usuario recibe 404; intentos de código limitados; rectificación validada, auditada sin valores y propagada; supresión rechazada con pedido activo y luego ejecutada con conservación mínima; plazo de 30 días y prórroga única; solicitudes duplicadas rechazadas
Menores (1)	el reporte de un menor deshabilita la cuenta y la suprime
Auditoría (5)	atributos completos y sin datos personales; saneamiento de secretos; cadena que detecta manipulación y abre un incidente; purga de retención con ancla; lectura restringida y auditada
Detección e incidentes (6)	accesos denegados reiterados; exportaciones anómalas; ciclo completo (contención, evidencia con SHA-256, solo lectura, recuperación, notificación y cierre); deshabilitar una cuenta del personal comprometida; solo el oficial contiene; criterios del art. 14 sexies
Recuperación (2)	rotación de llaves sobre toda la base y retiro de la llave anterior; un respaldo restaurado no revive a un titular suprimido

Tabla 16. Pruebas del Hito 3.

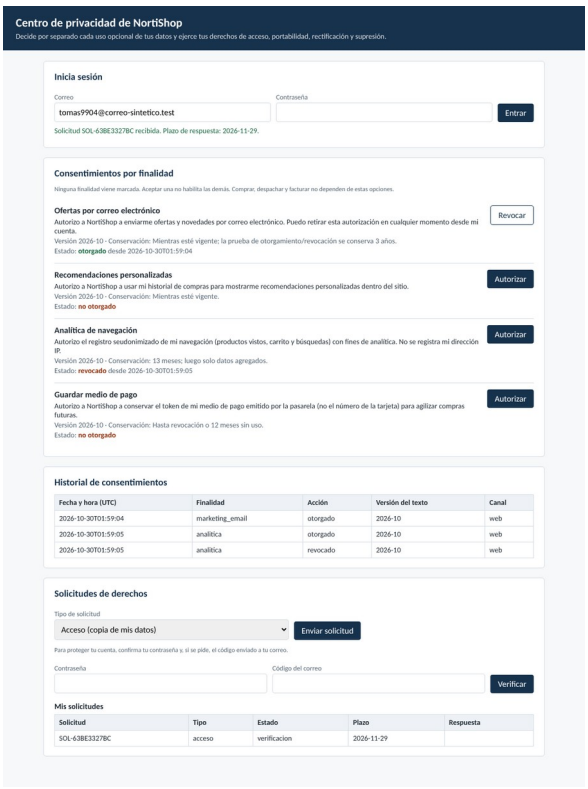


Figura 2. Solicitud de acceso en etapa de verificación: se pide la contraseña y el código enviado al correo.

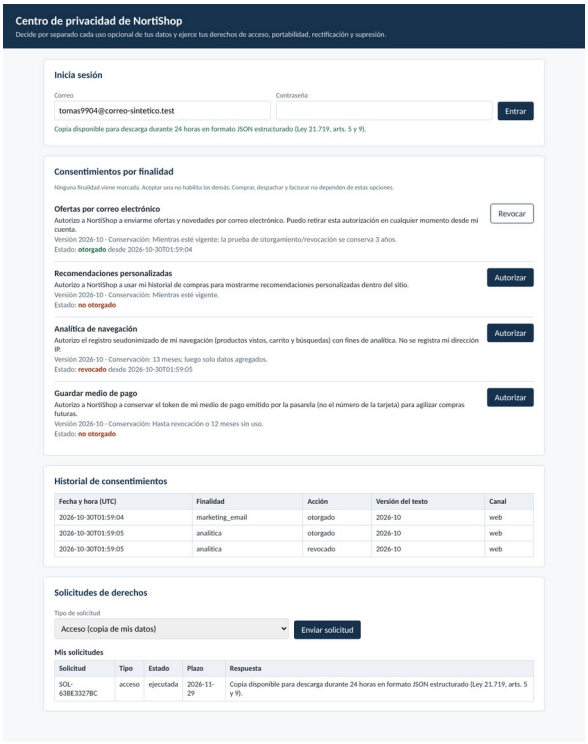


Figura 3. Solicitud ejecutada: respuesta con la base legal y descarga del archivo JSON.

Otros resultados disponibles en la carpeta `evidencias/`:

- `h3_exportacion_portabilidad_ejemplo.json`: archivo entregado al titular.
- `h3_ejercicio_derechos.json`: cada etapa de las cuatro solicitudes.
- `h3_auditoria_ejemplos.json`: 40 eventos reales y verificación de la cadena.

- `h3_alertas_e_incidente.json`: alertas y ciclo completo del incidente.
- `h3_consentimiento.json`: estado, historial y registro sellado.

8 Justificación técnica final

Decisiones principales. Se eligieron historiales solo de inserción con sellos HMAC para el consentimiento y la auditoría, porque la pauta exige trazabilidad y la mejor forma de garantizarla es que nada se sobrescriba. La verificación de identidad usa lo que el titular ya tiene (sesión, contraseña y correo) en vez de pedir documentos. La supresión diferencia lo que se elimina, lo que se minimiza y lo que se conserva bloqueado por ley, y deja una lápida para los respaldos. La detección reutiliza la auditoría, así que no requiere infraestructura adicional, y la contención actúa con banderas y revocaciones que no destruyen evidencia.

Riesgos mitigados. Consentimientos implícitos o extendidos a otras finalidades; marketing que sigue tras una revocación; entrega de datos a un suplantador; exportaciones con datos de terceros; supresiones incompletas o revertidas por un respaldo; registros que filtran datos personales; manipulación silenciosa de la auditoría; y respuestas tardías o improvisadas ante un incidente.

Limitaciones pendientes. El correo, el proveedor de mailing, la pasarela y el KMS están simulados. La purga automática de la evidencia de consentimiento a los 3 años y de las solicitudes cerradas está definida como política pero no programada (los triggers hoy impiden borrar consentimientos). El detector usa umbrales fijos, sin análisis de comportamiento. SQLite no permite separar físicamente la auditoría en otro servidor, como se haría en producción con un almacenamiento WORM. No hay segundo factor para el personal. Y los plazos internos de notificación y de conservación deben validarse con asesoría legal antes de operar.

9 Referencias

1. Biblioteca del Congreso Nacional. Ley 21.719 que regula la protección y el tratamiento de los datos personales; nuevo texto de la Ley 19.628: arts. 2 (definiciones), 5, 6, 7 y 9 (derechos), 11 (procedimiento y plazos), 12 y 13 (consentimiento y fuentes de licitud), 14 sexies (reporte de vulneraciones) y 16 quáter (niños, niñas y adolescentes). Vigencia: 01-12-2026. https://www.bcn.cl/leychile/navegar?idNorma=1209272
2. Biblioteca del Congreso Nacional. Ley 19.628 sobre protección de la vida privada, versión vigente hasta el 30-11-2026. Arts. 4, 11, 12 y 16.
3. Ley 21.663, Ley Marco de Ciberseguridad, y Decreto 295 (reglamento de reporte de incidentes): plazos de alerta temprana y de informes al CSIRT Nacional.
4. NIST SP 800-61 Rev. 2. Computer Security Incident Handling Guide.
5. NIST SP 800-92. Guide to Computer Security Log Management.
6. OWASP Logging Cheat Sheet y OWASP Authentication Cheat Sheet.
7. PCI Security Standards Council. PCI DSS v4.0, requisito 12.10 (respuesta a incidentes).
8. Material del curso: Seguridad y Protección de Datos; Informe Hito 1 y Hito 2 NortiShop.